

Un framework sémantique pour la cohabitation de politiques de sécurité hétérogènes

CHINOUN Riadh, DAHIR ALHUSSIN Mahmoud, MEZIANE Miloud, YAHIOUNE Smaïl

Encadrants : Mohand-Saïd Hacid, Salim Hariri

Résumé : Les systèmes informatiques modernes résultent souvent de fusions, d'évolutions progressives et de configurations par différents acteurs. Ceci entraîne des choix de politiques de sécurité incohérents et difficiles à harmoniser, qui peuvent se traduire par des conflits. Cet article propose d'explorer la littérature actuelle sur le sujet afin de proposer une première approche conceptuelle d'un cadre sémantique visant à faire cohabiter des politiques de sécurité de nature différente.

Abstract : Modern information systems are often the result of mergers, incremental evolution, and configurations performed by multiple actors. This context leads to inconsistent security policy decisions that are difficult to harmonize, ultimately generating conflicts. This paper reviews the existing literature on the subject and proposes a preliminary conceptual approach to a semantic framework designed to enable the coexistence of security policies with differing models and objectives.

Mots-clés : cybersécurité, gouvernance, politique, framework, sémantique, interopérabilité

1 Introduction

Dans le cadre de notre première année de master informatique à l'Université Claude Bernard Lyon 1, l'unité d'enseignement Projet d'Orientation Master (POM) propose aux étudiants d'effectuer des travaux de recherche sur des sujets portant sur différentes thématiques. Ces sujets sont encadrés par différents enseignants-chercheurs au sein de l'équipe d'enseignement. Notre choix s'est porté sur la thématique de la gouvernance en cybersécurité. Ce sujet a été proposé et encadré par M. HACID ainsi que par M. HARIRI.

Ce sujet porte sur la cohabitation de politiques de sécurité hétérogènes au sein des systèmes informatiques des organisations, ainsi que sur la conception d'un cadre sémantique commun à ces politiques pour qu'elles puissent coexister sans conflit. Pour cela, nous nous sommes basés sur une bibliothèque d'articles de recherche proposée par notre encadrant afin de comprendre comment ce problème a déjà été abordé. Ces articles nous ont permis de découvrir les différentes solutions existantes et leurs limites.

Les approches existantes (RBAC, ABAC, PBAC, norme NIST...) répondent chacune à des besoins spécifiques : certaines fournissent un ensemble d'exigences organisationnelles (ISO, NIST), tandis que d'autres proposent des solutions techniques pour exprimer et contrôler les politiques. Cependant, bien que ces approches permettent de répondre à un certain nombre de défis, elles ne sont pas suffisamment complètes pour qu'on puisse s'y limiter. C'est la raison pour laquelle les organisations sont amenées à les faire cohabiter. La cohabitation de ces différentes approches permet de répondre à la plupart des besoins existants, mais augmente le risque de conflits et d'incohérences, notamment au sein des systèmes multiniveaux et multiorganisationnels.

Afin d'explorer cette problématique, nous nous appuyons sur une analyse d'articles scientifiques existants afin d'identifier les solutions proposées, mais aussi leurs limites. Cette étude permettra ensuite d'entamer un travail de réflexion sur une approche conceptuelle visant à harmoniser des politiques de sécurité multiples.

2 Méthodologie adoptée

Notre travail a débuté par une phase d'appropriation du sujet. À partir d'articles et d'études scientifiques, chaque membre du groupe a d'abord mené des recherches sur plusieurs des articles proposés, sans toutefois s'y limiter. Le groupe s'est ensuite concerté à de nombreuses reprises afin de mettre en commun les idées et interrogations. L'objectif était que tous puissent se familiariser avec la thématique de la gouvernance et, plus particulièrement, avec les cadres de cybersécurité.

Durant le projet, nous avons pu organiser des réunions avec notre encadrant afin de clarifier certains points et interrogations, d'ajuster notre méthode de travail et de valider les directions prises pour la rédaction de ce rapport. Ces échanges ont été essentiels pour structurer notre travail et élargir nos perspectives sur le sujet. Les membres du groupe ont partagé leurs notes et documents sur l'espace de partage du LIRIS. Il n'était pas évident de pouvoir réunir régulièrement l'ensemble du groupe sur le campus, nous nous sommes donc organisés via un groupe WhatsApp et avons réalisé des réunions sur Discord.

Après la mise en commun de nos notes, nous avons réfléchi à un plan pour structurer l'article en concordance avec les recommandations de nos professeurs. Par la suite, nous avons réparti l'écriture des parties concernant l'état de l'art et avons réfléchi à une proposition.

3 État de l'art

3.1 Notions utiles

Avant d'étudier les travaux existants de la littérature actuelle, il est important de définir quelques concepts fondamentaux qui serviront de base à notre réflexion.

3.1.1 Politique de sécurité

Une politique de sécurité est un ensemble de règles, visant à limiter l'utilisation des ressources informatiques d'une organisation pour les protéger. Elle permet de répondre aux questions du type « QUI

peut faire QUOI sur QUELLE RESSOURCE ». Le « QUI » définit ici généralement un utilisateur (mais plus généralement un agent) qui va réaliser des opérations (le QUOI) sur des ressources d'une organisation. Ces politiques peuvent être purement de l'ordre technique (ex. : configuration d'un pare-feu, configuration d'un serveur, contrôle d'accès) ou organisationnelles (ex. : responsabilités des rôles, procédures).

3.1.2 Identity & Access Management (IAM)

Identity & Access Management (IAM), ou en français la gestion des identités et des accès, correspond à l'ensemble des processus et outils utilisés pour gérer les utilisateurs et leurs droits d'accès aux ressources d'une organisation. L'IAM est essentielle, car elle coordonne les processus d'authentification (= vérification de l'identité) et d'autorisation (= définition des droits et privilèges), assurant la sécurité des ressources et services selon les règles de sécurité définies.



Figure 1 - Fiche pratique IAM (© Anopixel)

3.1.3 Normes de sécurité

En outre, les organisations peuvent s'appuyer sur des normes et standards comme **NIST Cybersecurity Framework (CSF)** ou encore **ISO 27001**. Ces normes définissent des exigences aux niveaux organisationnel et méthodologique. Elles fournissent des lignes directrices à suivre pour la gestion des risques, mais donnent rarement des solutions techniques, ce qui les rend difficiles à appliquer en pratique.

3.1.4 Modèle de contrôle d'accès

Différentes approches permettent de mettre en œuvre les politiques de sécurité :

- **RBAC (Role-Based Access Control)** : l'accès aux ressources se fait selon des rôles attribués aux utilisateurs. Exemple : seul le rôle « professeur » peut éditer les notes d'un étudiant.
- **ABAC (Attribute-Based Access Control)** : l'accès est défini selon des attributs spécifiés sur des utilisateurs, des opérations et des ressources. Exemple : un professeur ne peut éditer que les notes de son cours « `note.course == maths && maths.teacher == Bob` ». On commence ici à introduire un peu de logique.
- **PBAC (Provenance-Based Access Control)** : l'accès à une ressource dépend de son historique. Exemple : les utilisateurs ne peuvent consulter un document que s'il a été mis à disposition par un utilisateur de confiance.

Chacune de ces approches permet de contrôler l'accès des utilisateurs aux ressources, mais, prises isolément, elles ne sont pas suffisamment expressives pour répondre à tous nos besoins. C'est pour cette raison que nous devons les faire cohabiter.

3.1.5 Cohabitation et interopérabilité

Dans cet article, le terme **cohabitation** désignera la coexistence de plusieurs politiques de sécurité (norme ou modèle technique) au sein d'un même système d'information ou entre systèmes interconnectés (de plusieurs organisations différentes, par exemple). Cette situation peut générer des conflits et des incohérences,

c'est la raison pour laquelle un cadre commun est nécessaire pour garantir un fonctionnement cohérent et sécurisé.

3.1.6 Framework sémantique

Les frameworks sémantiques visent à exprimer les politiques de sécurité dans un langage commun et structuré, permettant de représenter facilement les règles et relations entre les ressources et utilisateurs. En ayant un cadre commun, on facilite la détection de conflits dans un moteur d'inférence et on permet à différents modèles de cohabiter ensemble tout en gardant un système informatique cohérent. La cohérence est essentielle pour garantir la bonne sécurité des ressources d'une organisation.

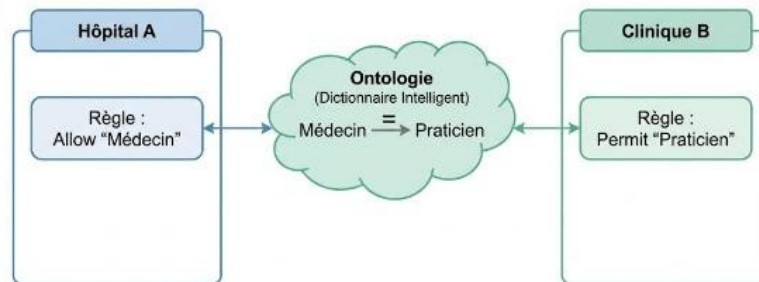


Figure 2 - Cadre sémantique pour l'interopérabilité des accès sur des systèmes d'information de deux organisations différentes

Dans la figure ci-dessus, nous avons affaire à une incohérence entre « Hôpital A » et « Clinique B » sur le nom du rôle assigné. Cette incohérence est résolue ici par un traducteur sémantique (ontologie). C'est un des nombreux exemples de conflits lorsque l'on essaye de faire cohabiter des modèles ou des systèmes différents ensemble.

3.2 Security by Design

Ce rapport est issu de la CISA, agence fédérale américaine chargée de la cybersécurité et des infrastructures. Il souligne les enjeux et les problèmes de sécurité actuels au sein des organisations. Il illustre notamment avec un exemple les conséquences potentiellement graves de cyberattaques ciblant des hôpitaux. L'objectif est ici de montrer la criticité de tels enjeux. Pour la CISA, l'enjeu principal se porte sur deux critères clés : « Secure by Design » et « Secure by Default ».

Secure by Design incite à intégrer les pratiques de sécurité directement dans la chaîne de conception afin de réaliser des logiciels correctement architecturés pour la sécurité et de réduire drastiquement la surface d'attaque face aux vulnérabilités classiques. Différents choix de conception peuvent faire la différence, tels que le recours à des pratiques de programmation sécurisées, qui peuvent réduire la surface d'attaque des logiciels. En bref, la sécurité doit devenir une exigence principale dans un produit, et cela, au même titre que la performance ou la fiabilité.

Secure by Default incite, quant à lui, à fournir des configurations par défaut déjà sécurisées. Les logiciels doivent être livrés avec des configurations sécurisées par défaut, garantissant un niveau de protection adéquat sans intervention de l'utilisateur.

La responsabilité de la sécurité doit incomber au fabricant, et non à l'utilisateur final. Le rapport souligne aussi la nécessité de la transparence chez les fabricants ; cela passe par une bonne communication sur les failles découvertes et corrigées afin de contribuer à sécuriser d'autres écosystèmes.

3.3 Integrating Information Security Policy Management with Corporate Risk Management for Strategic Alignment

Les organisations ont souvent tendance à considérer la sécurité comme un sujet technique délégué à une équipe IT (Information Technology), sans l'intégrer pleinement dans la stratégie globale de gestion des risques. Cet article propose d'utiliser un cadre commun pour aligner la gestion des risques de l'organisation et les politiques de sécurité sur une même stratégie. Ce cadre s'appuie sur les pratiques **Business Planning** et **Information Systems Planning** et définit pour cela quatre niveaux d'intégration :

Rapport de TER de CHINOUN Riadh, DAHIR ALHUSSIN Mahmoud, MEZIANE Miloud et YAHIOUNE Smaïl

1. Séparé : plus bas niveau, pas d'alignement, ce que l'on cherche à éviter
2. Séquentiel : la stratégie d'entreprise influence les politiques de sécurité techniques
3. Réciproque : influences mutuelles entre les deux
4. Intégration complète : tout le développement se fait en simultané dans un même processus complètement synchronisé

L'intégration complète est l'objectif visé, mais, bien que des normes existent (ex. : NIST, ISO 27001), aucune ne propose de méthode concrète pour l'atteindre. En pratique, les organisations vont souvent déléguer ces sujets considérés trop techniques à une équipe IT, séparant ainsi la politique de sécurité de la gestion des risques.

L'approche CRP-ISP intègre l'ISP (politique de sécurité de l'information) dans un framework de gestion des risques, structuré en quatre étapes : évaluation des risques, traitement des risques, communication des risques et suivi. Les politiques de sécurité sont hiérarchisées sur trois niveaux :

1. **Stratégique (People) : lié à l'intention, aux rôles, aux responsabilités ou à la gouvernance**
2. **Procédural (Process) : un niveau intermédiaire entre la technique et la stratégie, on parle ici de gestion des accès ou de séparation des tâches.**
3. **Technologique (Technology) : la partie technique (configuration d'applications critiques comme les pare-feu, l'authentification, l'autorisation, les politiques de chiffrement, etc.)**

La couche la plus basse (Technology) dérive des politiques de sécurité, on devient donc « policy-driven » et non plus « technology-driven ». On nous propose pour y arriver une méthode théorique basée sur l'évaluation des risques en analysant l'environnement (méthode SWOT citée) et la création de politiques de sécurité associées. À partir de cela, nous développons un plan de sécurité et nous communiquons avec l'ensemble de l'organisation pour la sensibiliser et la former. On procède à des analyses en continu des performances et des feedbacks.

La sécurité devient donc un élément de gouvernance pleinement intégrée à la stratégie de gestion des risques et de l'entreprise. Elle vise à atteindre une politique structurée et cohérente, permettant de facilement comprendre les différentes dépendances entre ressources autour d'une stratégie commune.

Cependant, les auteurs reconnaissent le caractère trop théorique de la méthode et soulignent la nécessité de tester empiriquement la méthode. Cet article met en évidence l'importance d'intégrer la sécurité au sein de la stratégie de l'entreprise en matière de gestion des risques et d'arrêter d'en faire un sujet uniquement technique.

On retrouve l'idée d'une sémantique multicouche, le fait de faire dériver les règles techniques de politiques de sécurité (policy-driven). Cependant, l'article n'aborde pas la cohabitation multi-organisationnelle et ne donne pas de sémantique formelle.

3.4 A Layered Architecture for Policy-Based Management in Service Oriented Computing

Après avoir abordé la philosophie de conception et la gouvernance stratégique, il est nécessaire de se pencher sur l'architecture technique permettant la collaboration entre entités distinctes. Cet article de He et Yang s'attaque spécifiquement aux défis du Service Oriented Computing (SOC), un paradigme où les applications ne sont plus des blocs isolés, mais des assemblages dynamiques de services web.

Le problème soulevé est celui de l'hétérogénéité : lorsque des organisations collaborent "à la volée", elles possèdent chacune leurs propres règles de sécurité, souvent incompatibles ou exprimées différemment. Les auteurs soulignent le risque d'incohérence, prenant l'exemple critique d'un dossier médical partagé entre un hôpital et un centre de recherche sans le consentement explicite du patient.

Pour résoudre ce problème d'interopérabilité, l'article propose une architecture nommée "PD-AC" qui décompose la politique de sécurité en trois couches logiques, permettant une comparaison standardisée :

- **OSP (Organization Policy) : les règles globales valables pour toute l'entité (ex. : standards de certificats).**
- **RSP (Role Policy) : les règles liées aux métiers, définissant les rôles, les privilèges et les accréditations nécessaires.**
- **SSP (Service Policy) : les règles techniques spécifiques au service, incluant les "Provisions" (actions préalables) et les « Obligations » (actions ultérieures).**

L'apport majeur de ce papier réside dans sa méthodologie de résolution de conflits lors de la collaboration. Les auteurs définissent des règles mathématiques pour fusionner les politiques : l'Intersection pour les droits d'accès (on ne garde que le niveau de permission commun aux deux entités pour maximiser la sécurité) et l'Union pour les contraintes (on cumule les exigences de sécurité de chaque partie, comme un mot de passe ET un badge).

Cet article est fondamental pour notre projet, car il nous fournit le modèle structurel. Il nous permet de passer d'une vision stratégique à une implémentation technique concrète des politiques. Nous retenons particulièrement la hiérarchisation (OSP/RSP/SSP) qui servira de squelette à notre propre modèle de données. Cependant, bien que ce modèle gère la structure syntaxique des règles, il ne résout pas entièrement le problème de la sémantique (le sens des mots utilisés dans les règles), ce qui nécessitera l'apport d'autres travaux sur les ontologies.

3.5 A Provenance-based Access Control Model

L'article nous propose PBAC (Provenance-Based Access Control) : utiliser l'origine, l'historique et les dépendances des données pour décider qui peut faire quoi dans un système. L'intérêt d'utiliser la provenance est d'avoir une traçabilité des données et des différents usages qui en sont faits, de versionner et d'analyser des workflows. On aura donc un contrôle basé sur l'origine (« dynamic separation of duty » [0]).

Les auteurs s'appuient ici sur **Open Provenance Model (OPM)** qui permet d'avoir une sémantique pour capturer des données grâce à trois éléments :

- **Artifacts : Ressources / Données**
- **Processes : Actions / Opérations**
- **Agents : Utilisateurs (auteurs des actions)**

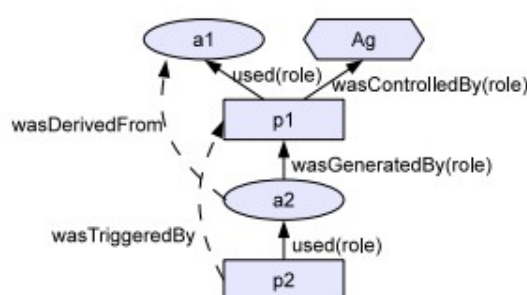


Fig. 1. OPM Causality Dependencies

Figure 3 – Graphe de provenance basé sur la causalité

Dans cet article, les auteurs se sont limités à trois dépendances directes : *used* (celui qui a utilisé), *wasGeneratedBy* (l'objet qui a été généré par une action), *wasControlledBy* (l'action qui a été exécutée par un utilisateur). Les auteurs restent ouverts à des extensions du modèle.

3.6 Security in Smart Home Environment

Après avoir vu l'importance de la structure avec He & Yang, nous avons étudié cet article de Baddi et al. qui se concentre sur la sécurité dans les maisons connectées (Smart Home). C'est un domaine intéressant pour notre sujet, car il fait intervenir de nombreux objets différents (capteurs, caméras, électroménager) qui doivent communiquer entre eux.

Le problème soulevé : la rigidité des systèmes actuels. Les auteurs partent d'un constat critique : les modèles de sécurité traditionnels, comme RBAC (gestion par rôles), sont trop statiques. Ils définissent des droits fixes sans tenir compte de ce qui se passe autour. Par exemple, une règle classique autorise un utilisateur à ouvrir une porte ; elle ne vérifie pas l'heure qu'il est ni si une alarme est activée. Or, dans un environnement dynamique, le contexte est essentiel pour décider si une action est dangereuse ou non.

Pour résoudre ce problème, les auteurs proposent une approche sémantique fondée sur l'utilisation d'une ontologie. Concrètement, c'est un modèle qui sert de « vocabulaire commun » afin que tous les appareils comprennent de la même façon ce qu'est un utilisateur ou une action.

L'apport technique majeur de ce papier est l'utilisation du langage SWRL (Semantic Web Rule Language). Au lieu de simples permissions, les auteurs écrivent des règles logiques qui incluent le contexte, par exemple : « Si une présence est détectée, alors allumer la lumière. »

4 Problématiques identifiées

4.1.1 Cohabitation des politiques hétérogènes

Les modèles d'accès existants (ex. : RBAC, ABAC, PBAC) et les normes (ex. : NIST CSF, ISO 27001) sont efficaces individuellement, mais ne répondent pas à tous les besoins et n'ont pas été conçus pour coexister dans un même système. La conséquence est l'apparition de conflits et d'incohérences dans les politiques de sécurité pouvant mener à de graves failles. Cette problématique souligne le besoin crucial d'un cadre sémantique commun pour détecter et résoudre ces conflits.

4.1.2 Limite de l'approche policy-driven analysée

Les études portant sur les approches CRP-ISP ou PD-AC font le choix de structurer les politiques en niveaux, mais restent essentiellement théoriques. Les chercheurs admettent eux-mêmes le manque de preuves d'efficacité pratique, car elles sont difficiles à appliquer concrètement (on retrouve ce même problème avec les normes type NIST CSF). Un framework sémantique commun pourrait apporter une solution quant à la mise en œuvre de telles approches.

4.1.3 Manque de prise en compte du contexte d'exécution

Les modèles traditionnels cités dans ce rapport tels que RBAC ou ABAC sont par conception statiques. Ils ne prennent pas en compte le contexte d'exécution et l'historique des actions utilisateurs. L'article portant sur PBAC (Provenance Based Access Control) apporte un modèle capable de prendre en compte ces historiques tels que les logs, les états d'un système ou encore la provenance des données. En se limitant à des modèles statiques, nous limitons notre champ d'action pour l'écriture de politiques capables d'exprimer avec finesse les souhaits d'une organisation en matière de sécurité.

4.1.4 Transparence et responsabilité

L'article [2] soulignait l'importance d'avoir des politiques de sécurité alignées sur la stratégie globale d'une organisation par souci de transparence et pour éviter de déléguer l'entière responsabilité de la sécurité à l'équipe IT. Sans cela, il est difficile d'avoir une vision globale des risques et de garantir cohérence et conformité. Ici encore, un framework sémantique commun permettrait d'avoir une vue globale de la gestion des risques d'une entreprise et de l'intégration des politiques de sécurité associées.

4.1.5 Limites des normes et standards

Comme souligné dans [2], des normes existent pour donner un cahier des charges d'exigences et des lignes directrices à suivre, mais n'apportent pas de solutions techniques concrètes. Dans la pratique, les

Rapport de TER de CHINOUN Riadh, DAHIR ALHUSSIN Mahmoud, MEZIANE Miloud et YAHIOUNE Smaïl

organisations ne peuvent pas mettre en œuvre ces standards ; un cadre sémantique peut fournir une implémentation concrète pour harmoniser ces normes et modèles.

5 Proposition d'une première approche conceptuelle

Notre approche conceptuelle reprendrait l'idée d'une approche en trois couches :

- Niveau 1 : **Stratégie** qui définit les règles sémantiquement
- Niveau 2 : **Traduction** qui harmonise les différentes données issues du système
- Niveau 3 : Moteur d'inférence qui, à partir de données en entrée, est capable de prendre des décisions cohérentes et de détecter les conflits

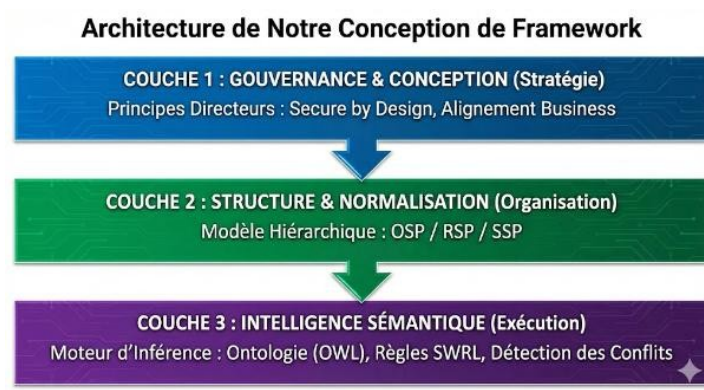


Figure 4 - Architecture en trois couches

La stratégie exprime l'intention de sécurité de l'organisation ; ce niveau est indépendant de toute implémentation technique. À ce niveau, on ne parle pas de rôles ou de règles, mais plutôt de sens, de valeurs et de limites dans un système. On se pose la question « Qu'est-ce qu'une action autorisée dans notre organisation ? » sans se demander comment l'appliquer concrètement. Une organisation doit protéger ses ressources qui peuvent correspondre à des données sensibles ou à des personnes (ex. : employé, client) avec les enjeux de responsabilités légales ou éthiques. Un hôpital se doit de protéger la confidentialité du patient ; il ne se pose à ce stade pas encore les questions « comment dois-je protéger telle table dans la base de données ? » ou « quel serveur de fichiers doit être sécurisé avec quel rôle ? ». Pour cela, on doit déterminer le sens des actions en s'alignant sur la politique de gestion des risques de l'organisation. L'hôpital veut protéger la vie privée de ses patients : comment peut-on donner du sens aux actions ? La finalité est de diagnostiquer ; l'action est réalisée par le médecin en charge du patient, et un rapport peut être établi à la suite de cette action.

Le niveau 2 correspond à la traduction ou plus précisément à un alignement sémantique entre les différents modèles. On ne se contente pas de traduire des règles sémantiques, mais on doit à ce niveau réconcilier les différents modèles de sécurité. Par exemple, un pare-feu parle en flux de données, un annuaire parle de rôles et une norme parle en exigences. Tous ces modèles permettent d'exprimer des politiques de sécurité et de résoudre des problématiques, mais parlent un langage différent. Cette couche de traduction collecterait l'ensemble de ces informations pour les relier à des intentions communes. On donne une vraie signification organisationnelle à des configurations techniques. Tout ce travail permet d'aboutir à une configuration dans un format unifié et standard que le moteur d'inférence (niveau 3) pourra comprendre. Ce niveau 2 correspond au cœur de notre sujet qui consiste à trouver une sémantique commune pour les politiques de sécurité existantes.



Figure 5 - Exemple d'un format JSON qui unifierait des politiques RBAC et Provenance-BAC

Le niveau 3 qui correspond au moteur d'inférence se baserait sur l'ensemble des données et règles issues du cadre sémantique ; il répond aux questions du type « AGENT peut-il réaliser ACTION sur RESSOURCE ? » et pour cela, il doit certes se baser sur les politiques de sécurité, mais il doit aussi être capable de résoudre les conflits quand deux politiques se contredisent. Le moteur d'inférence doit aussi pouvoir justifier ses choix.

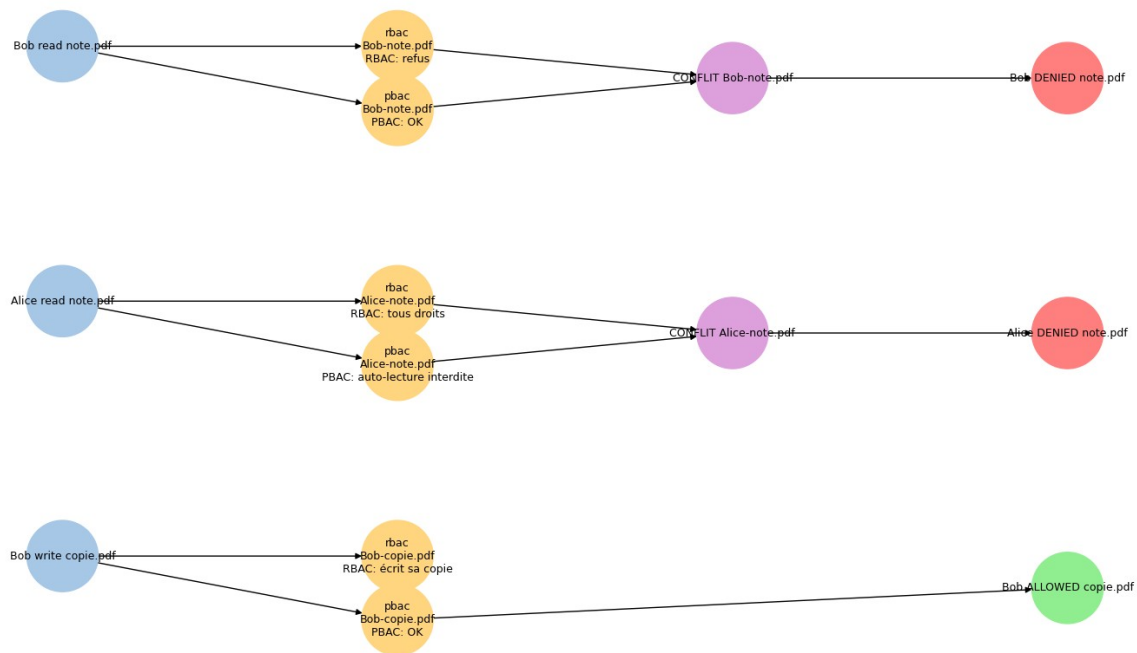


Figure 6 - Exemple de décisions prises par un moteur d'inférence

6 Perspectives

Un défi concerne encore la méthode permettant de résoudre un conflit. Dans l'exemple précédent, nous adoptons une approche « deny override » : en cas de conflit, on interdit. Le problème d'une telle approche est que le système peut facilement se retrouver bloqué en attente d'une résolution manuelle.

Un autre défi, plus complexe, concerne la traduction dans une sémantique commune : les modèles, outils et applications existants sont si nombreux qu'il est très difficile de traduire leurs intentions dans un langage commun sans perdre d'information. Il y aurait de nombreuses subtilités à prendre en compte. Ici, l'usage du machine learning peut s'avérer intéressant. On pourrait permettre à un modèle ML de s'entraîner sur des logs pour identifier des usages, des incohérences ou encore détecter des règles implicites qu'un outil ne formalise pas, mais qu'un framework sémantique aurait besoin de connaître pour fonctionner correctement. Cependant, l'usage du machine learning doit être bien dosé et ne pas prendre la place d'un moteur d'inférence strictement basé sur des règles, car la prise de décision en matière de sécurité doit être prévisible et fondée sur un raisonnement véritablement explicable.

Il reste aussi à trouver un moyen de pousser les organisations à intégrer cette formalisation des risques au niveau organisationnel et non plus seulement à un niveau technique ; c'était un problème d'alignement relevé par [2]. Cela reste un défi majeur, et les approches proposées n'ont pas encore fait leurs preuves en pratique.

7 Retour d'expérience

Ce projet nous a permis de nous initier au monde de la recherche scientifique. Il a fallu commencer par l'analyse d'articles de recherche et d'études scientifiques ; beaucoup d'articles abordaient des concepts que la plupart d'entre nous n'avaient jamais abordés. Il était aussi important d'adopter une lecture critique en se posant souvent des questions et en faisant des liens avec les autres documents.

Nous avons ainsi découvert la thématique de la gouvernance en cybersécurité, une branche du domaine à laquelle on ne pense pas de prime abord, mais qui constitue pourtant un enjeu majeur dans les entreprises. Les différents articles de recherche fournissent de nombreuses informations ; il était important d'apprendre à identifier les contributions pertinentes pour notre sujet de recherche, à structurer l'information et à prendre en compte les limites des approches proposées en identifiant les problématiques.

Par ailleurs, le projet a mis en évidence la difficulté à trouver un équilibre entre la phase de recherche et d'exploration des documents et la phase de rédaction du rapport. Il a fallu mettre en place une méthodologie de travail pour ne rien délaissier : réaliser une analyse approfondie pour comprendre et rester cohérent puis pouvoir restituer tout cela dans un rapport en réfléchissant à une proposition et des perspectives.

8 Conclusion

La gouvernance en cybersécurité est un sujet majeur. Un de ses défis est de répondre à la question : comment aligner la vision d'une organisation en matière de gestion des risques sur des politiques de sécurité techniques qui n'ont pas été conçues pour cohabiter. L'une des étapes permettant de répondre à ce défi, et qui constitue le cœur de cet article est de développer un framework sémantique capable d'unifier les configurations des différentes politiques de sécurité dans un langage commun. Les contributions de la littérature actuelle apportent des approches et idées, mais proposent rarement des implémentations techniques concrètes en raison de la complexité de ce problème. Par conséquent, nous proposons une première approche conceptuelle afin, dans un premier temps, de formaliser correctement une architecture pour découper les différents éléments à implémenter, puis de réfléchir aux problèmes qu'un framework sémantique devra être capable de résoudre, ce qui constitue le niveau 2 de l'architecture en trois couches.

9 Bibliographie

- [1] CISA : Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Security-by Design and Default – 2023 https://www.cisa.gov/sites/default/files/2023-06/principles_approaches_for_security-by-design-default_508c.pdf
- [2] Maria Corpuz, Paul Barnes : Integrating Information Security Policy Management with Corporate Risk Management for Strategic Alignment – 2010 - https://www.researchgate.net/publication/268414373_Integrating_Information_Security_Policy_Management_with_Corporate_Risk_Management_for_Strategic_Alignment
- [3] Jaehong Park, Dang Nguyen, Ravi Sandhu : A Provenance-based Access Control Model – 2012 - https://profsandhu.com/confnc/misconf/pst12_pbac_model.pdf
- [4] Petar Radanliev, Dave De Roure, Jason R.C. Nurse, Razvan Nicolescu, Michael Huth : Integration of Cyber Security Frameworks, Models and Approaches for Building Design Principles for the Internet-of-Things in Industry 4.0 – 2018 - https://www.researchgate.net/publication/325436797_Integration_of_Cyber_Security_Frameworks_Models_and_Approaches_for_Building_Design_Principles_for_the_Internet-of-things_in_Industry_40
- [5] Daisy Daiqin He, Jian Yang : Security Policy Specification and Integration in Business Collaboration – 2007 - [https://research-management.mq.edu.au/ws/portalfiles/portal/62174311/Publisher%20version%20\(open%20access\).pdf](https://research-management.mq.edu.au/ws/portalfiles/portal/62174311/Publisher%20version%20(open%20access).pdf)
- [6] Mostofa Ahsan, Kendall E. Nygard, Rahul Gomes, Md Minhaz Chowdhury, Nafiz Rifat, Jayden F Connolly : Cybersecurity Threats and Their Mitigation Approaches Using Machine Learning—A Review – 2022 - https://www.researchgate.net/publication/361906485_Cybersecurity_Threats_and_Their_Mitigation_Approaches_Using_Machine_Learning-A_Review
- [7] Iqbal H. Sarker, A. S. M. Kayes, Shahriar Badsha, Hamed Alqahtani, Paul Watters, Alex Ng : Cybersecurity data science: an overview from machine learning perspective – 2020 - https://www.researchgate.net/publication/342591771_Cybersecurity_data_science_an_overview_from_machine_learning_perspective
- [8] Georgios Mantas, Dimitris Lymperopoulos, Nikos Komninos : Security in Smart Home Environment – 2010 : https://www.researchgate.net/publication/232923869_Security_in_Smart_Home_Environment

10 Annexes

10.1 Notes de la deuxième réunion

- Structurer nos différentes analyses
- Pas de réalisation technique demandée
- Pas de write & forget
- Rester critique et constructif entre nous
- Niveau de détail à avoir : expliquer à peu près (comparaison SGBD avec tables etc.)
- Formaliser : ce qu'on fait, pourquoi, notre proposition (rester critique)

10.2 Notes et analyse des documents

10.2.1 Security by Design (CISA)

https://www.cisa.gov/sites/default/files/2023-06/principles_approaches_for_security-by-design-default_508c.pdf

Le document souligne les enjeux et problèmes de sécurité actuels (exemple des hôpitaux ayant subi des cyberattaques...) et a l'air d'être surtout destiné aux fabricants de matériel et de logiciels (même si, ici, on se concentre sur les logiciels). Ils sont incités à adopter deux critères clés : « Secure by Design » et « Secure by Default ».

Secure by Design : intégrer les pratiques de sécurité directement dans la chaîne de conception pour faire des produits déjà bien architecturés pour la sécurité (cela permet de réduire la surface d'attaque et d'anticiper des vulnérabilités classiques mais importantes). On applique aussi le principe du moindre privilège (lien avec les frameworks présentés ensuite). On évoque aussi des langages de programmation modernes. Ils offrent une gestion plus sûre de la mémoire (cf. Rust). En bref : la sécurité est une exigence principale d'un produit, au même titre que les performances, avant même le début de sa conception, puisqu'elle doit intégrer le cycle complet de développement logiciel (SDLC).

Secure by Default : l'idée ici est d'éviter à l'utilisateur/au client d'être obligé de configurer pour rendre sécurisé, mais plutôt de fournir des configurations par défaut déjà suffisamment sûres. Par exemple, mettre en place une politique de mots de passe longs par défaut, forcer la 2FA ou encore attribuer des accès minimaux à chaque rôle (principe du moindre privilège).

Autre point important : étant donné que la charge de ces principes incombe au fabricant, il ne peut pas essayer de les faire payer aux clients.

Le fabricant doit être le plus transparent possible. Par exemple, si une faille est découverte et corrigée, il faut communiquer à ce sujet et partager les informations pour contribuer à sécuriser d'autres écosystèmes.

Le document renvoie aussi les fabricants vers des pratiques SBD comme le « SSDF / NIST SP 800-218 » ou le « SBOM »...

Cet article souligne l'importance de sécuriser un système, mais il n'est pas directement lié avec le sujet de recherche.

10.2.2 Integration of Cyber Security Frameworks, Models and Approaches for Building Design Principles for the Internet-of-Things in Industry 4.0

Ce document est une étude qui adopte des méthodes théoriques pour comprendre comment intégrer des frameworks et approches de cybersécurité à l'industrie de l'IoT.

L'IoT désigne tous les objets connectés. Ils se connectent à un réseau et sont capables de partager et de récolter des données. Cela soulève nécessairement des questions de sécurité et de vie privée.

L'objectif de l'étude est de susciter un débat entre les praticiens et les universitaires pour réfléchir à de nouveaux principes de design pour évaluer le cyber-risque des appareils IoT (précisément ceux issus de la 4e révolution industrielle). On ne manque pas de frameworks, mais ils s'intègrent mal entre eux.

Recovery : capacité du système à restaurer les fonctions critiques.

Certains frameworks sont qualitatifs, comme OCTAVE ou TARA ; ce sont des modèles qui couvrent les dimensions descriptive et organisationnelle : définir ce qui est critique, les incidents qui peuvent survenir, le niveau de recovery, qui doit intervenir, si le système peut fonctionner de manière dégradée et dans quelle mesure...

D'autres frameworks, comme FAIR ou RiskLens, sont quant à eux quantitatifs ; ils permettent de modéliser des coûts (pertes financières par exemple), des fréquences d'incident, des durées, des impacts.

Les modèles actuels ne mesurent pas, ou peu, le coût réel du recovery, pourtant crucial.

Cela crée un décalage avec NIST (méta-framework), qui permet de donner un cadre de structuration, ou avec ISO 27001.

ISO 27001 : norme reposant sur la confidentialité, l'intégrité et la disponibilité de l'information.

Cet article est également intéressant pour souligner l'importance de prendre en compte le recovery dans les frameworks existants, mais il est trop axé sur les normes.

10.2.3 A Provenance-based Access Control Model

- Objectif : l'article propose PBAC (Provenance-Based Access Control), c'est-à-dire utiliser l'origine, l'historique et les dépendances des données pour décider qui peut faire quoi dans un système.
- Problématique actuelle : les modèles classiques sont trop rigides (RBAC, MAC...) et, par conséquent, difficiles à configurer pour un système complet. Ils ne prennent pas en compte les dépendances interobjets, l'historique d'utilisation ou encore l'origine des données.
- Intérêt d'utiliser la provenance : elle permet d'avoir une traçabilité des données et des différents usages qui en sont faits, de versionner et d'analyser des workflows. On aura donc un contrôle basé sur l'origine, une "dynamic separation of duty", un workflow control et un object version control.
- OPM : les auteurs de l'article s'appuient ici sur OPM (Open Provenance Model) ; on retrouve une sémantique classique qui permet de capturer des données grâce aux éléments suivants :
 - => Artifacts : Données / objets (ex. : review, submitted paper, etc.)
 - => Processes : Actions (ex. : upload, submit, grade, etc.)
 - => Agents : Utilisateurs (ceux qui réalisent les actions)
- Modèle présenté dans l'article : le graphe de provenance est orienté et acyclique, et sa sémantique est basée sur la causalité. Exemple :
 - Les auteurs se limitent volontairement à trois dépendances directes (pas de dépendances indirectes) :
 - => used : Action utilise Objet
 - => wasGeneratedBy : Objet généré par Action
 - => wasControlledBy : Action exécutée par Utilisateur
 - Chaque action est liée à UN SEUL utilisateur : de cette manière, on sait directement qui a déclenché quoi ; pour des actions collaboratives, on peut se reposer sur plusieurs actions distinctes ou étendre le modèle.
 - used et wasGeneratedBy sont associés à des rôles

- Les auteurs établissent une distinction claire entre PAC (contrôler l'accès aux données de provenance) et PBAC (utiliser la provenance pour contrôler l'accès aux données) ; les deux se complètent.
- PBAC ne remplace pas les autres modèles ; il peut se combiner avec ABAC, RBAC...
- Extensions présentées avec ajout de provenance déclarée par l'utilisateur, par exemple
- Vocabulaire :

Acting Users : utilisateurs

Action Instances : actions concrètes

Action Types : types d'actions

Objects : ressources

Object Roles : rôles des objets dans une action

Requête : UTILISATEUR => ACTION => OBJET (avec RÔLE)

10.2.4 Integrating Information Security Policy Management with Corporate Risk Management for Strategic Alignment

L'article présente une manière d'aligner la politique de sécurité de l'information (ISP) sur la gestion des risques d'entreprise (CRP).

Dans l'idée, c'est surtout de montrer le problème actuel qui est que la sécurité dans une entreprise est un sujet technique délégué à "l'équipe informatique". On ne l'intègre pas dans la stratégie globale de gestion des risques de l'entreprise, ce qui est problématique.

Les auteurs proposent donc d'utiliser un cadre commun pour gérer les risques de l'entreprise et la politique de sécurité, afin de les aligner sur une même stratégie.

Les auteurs s'appuient sur ce qui se fait en Business Planning et en Information Systems Planning et divisent cela en quatre niveaux d'intégration.

1. Séparé : le plus bas, sans alignement, ce que l'on cherche à éviter à tout prix
2. Séquentiel : c'est mieux ; la stratégie de l'entreprise influence les politiques de sécurité techniques de l'IT
3. Réciproque : encore mieux ; on observe des influences mutuelles entre les deux
4. Intégration complète : tout le développement se fait simultanément dans un même processus, avec une synchronisation complète, ce que recherche l'équipe de chercheurs

Des standards et des normes existent (NIST, ISO 27001...) ; ils donnent des recommandations, mais ne proposent aucune méthode concrète pour atteindre le niveau d'intégration complet. Cela donne des lignes directrices, mais ce n'est pas assez pour atteindre le niveau 4 voulu.

Vu que c'est technique, on préfère déléguer totalement à l'équipe informatique (niveau 1).

Finalement, les auteurs proposent une solution : intégrer l'ISP (= politique de sécurité de l'information), qui est une problématique « technique », dans un « framework de gestion des risques » ; la gestion des risques de l'entreprise se ferait dans ce framework en quatre étapes.

"CRP-ISP Approach"

- 1 : Risk assessment process (derived from Risk Management Policy)
- 2 : Risk treatment process (facilitating the development and implementation of the Risk Mitigation Plans)
- 3 : Risk communication process (facilitating awareness of the Risk Communication Plan)

Rapport de TER de CHINOUN Riadh, DAHIR ALHUSSIN Mahmoud, MEZIANE Miloud et YAHIOUNE Smaïl

4 : Risk review and monitoring process (assuring accuracy of the overall risk assessment)

Ils décident de hiérarchiser les politiques de sécurité sur trois niveaux/couches :

1. Niveau stratégique (People) : tout ce qui est lié à l'intention, aux rôles, aux responsabilités et à la gouvernance
2. Niveau procédural (Process) : c'est ce qui précède la technique sans en relever encore ; on parle de gestion des accès, des incidents ou encore de séparation des tâches
3. Niveau technologique (Technology) : ici, on entre dans la technique et l'on parle de configuration de pare-feu, d'authentification, d'autorisation, de chiffrement, de logs, etc.

La couche la plus basse (technique) dérive des politiques de sécurité, on devient policy-driven et non plus technology-driven.

Quatre étapes sont proposées pour atteindre ce but :

1. Évaluation des risques de sécurité : on analyse l'environnement (méthode SWOT) et on crée des politiques de sécurité ainsi que la hiérarchie associée
2. Développement du plan de sécurité : on déploie des contrôles ; la méthode PDCA est citée
3. Communication : il faut informer tout le monde de ce que l'on fait, en formant et en sensibilisant, et effectuer du reporting ; cela évite les incohérences
4. Monitoring : on mesure en continu les performances et on récolte régulièrement des retours

=> La sécurité doit devenir un élément de gouvernance pleinement intégrée à la stratégie de gestion des risques d'une entreprise

=> L'objectif est d'arriver à une politique structurée et cohérente où l'on peut facilement comprendre les dépendances entre les ressources avec une stratégie commune

Les auteurs reconnaissent toutefois qu'il faut tester empiriquement la méthode pour évaluer sa réelle efficacité.

Conclusion de ce document : il vise à montrer que la sécurité doit faire partie de la stratégie de l'entreprise et non plus être gérée séparément par une équipe technique uniquement.

Pour notre sujet :

on retrouve l'idée d'une sémantique multicouche (cohérente avec plusieurs politiques de sécurité), le point policy-driven est plutôt intéressant (faire dériver les règles techniques de politiques de sécurité, ce qui est très utile dans notre cas).

On retrouve aussi le besoin que tout le monde s'aligne (= résolution de conflits).

On peut faire un pont avec l'ontologie OWL du précédent article sur le besoin d'un registre de contrôle et de risques.

Environnement hétérogène : plusieurs organisations, plusieurs frameworks, plusieurs domaines techniques
=> besoin d'un méta-framework d'intégration (lien avec le niveau 4 de la méthode de l'article).

Un dernier point sur la définition de « système » en lien avec notre sujet : il faut bien distinguer les différents niveaux (comme pour les couches CRP-ISP) ; on peut vouloir concevoir quelque chose de :

=> technique : une application de type pare-feu, serveur web, RDAP, service hébergé, etc.

=> organisationnel : on parle alors de « système RH », « système de paiement », « système IAM », etc.

La question de l'interorganisationnel consiste à se demander : si je veux faire cohabiter les systèmes de deux entreprises différentes et leur faire partager un même écosystème, comment procéder ?

Dans ce cas, je fais cohabiter des politiques de sécurité qui peuvent être à un niveau organisationnel (gérer des personnes, des autorisations) et à un niveau technique (j'ouvre un port réseau sur tel serveur, j'ouvre l'accès à ce site web à l'équipe RH...) ; on veut un framework qui parte du niveau organisationnel/stratégique et qui descende vers le niveau technique (PBAC, RBAC...).

10.3 Transcription vidéo

Diapo 1 : « Bonjour à tous, dans cette vidéo, nous allons vous présenter un enjeu portant sur la création d'un cadre sémantique pour la cohabitation de politiques de sécurité hétérogènes. Finalement, nous proposerons une première approche conceptuelle pour répondre à cette question. »

Diapo 2 : « En trois minutes, nous allons d'abord vous expliquer le problème de fond avec un exemple concret, puis nous vous détaillerons notre approche conceptuelle, avant de conclure sur les perspectives futures de notre travail. »

Diapo 3 : « Aujourd'hui, les systèmes informatiques sont de plus en plus interconnectés, mais ils ne partagent pas toujours le même vocabulaire. C'est ce qu'on appelle des politiques hétérogènes. Prenons un exemple concret : un hôpital doit partager le dossier d'un patient avec une clinique. Du côté de l'hôpital, l'utilisateur a le rôle "Médecin". Du côté de la clinique, le système n'autorise l'accès qu'au rôle "Praticien". Pour nous, c'est la même chose. Mais pour la machine, ce sont deux rôles distincts. Elle ne comprend pas l'équivalence et bloque l'accès. »

Diapo 4 :

« Mais alors, pourquoi est-ce que ça bloque ? Tout simplement parce que les différents outils informatiques ne parlent pas la même langue et n'ont pas été conçus pour fonctionner ensemble. Dans la pratique, une organisation a une vision globale de sa sécurité. Sauf que les outils qui protègent le système appliquent ces règles chacun à leur manière. Il est donc très difficile de les configurer de manière cohérente. »

Diapo 5 : « C'est exactement pour répondre à ce problème que nous avons pensé à notre solution. Je laisse mon camarade vous expliquer en quoi elle consiste. »

Diapo 6 :

« Pour résoudre ce problème, nous proposons un framework sémantique organisé en trois couches : la Stratégie, la Traduction et le Moteur d'inférence. Cette architecture permet de créer une liaison entre ces différentes règles pour que les systèmes se comprennent enfin. »

Diapo 7 : (Couche 1)

« Commençons par la couche numéro 1 : la Stratégie. À ce niveau-là, on oublie complètement la technique. On se pose juste une question : qu'est-ce qu'on veut protéger dans la vraie vie ? Par exemple : "Notre priorité, c'est de protéger le secret médical". C'est cette intention purement humaine et éthique qui va servir de boussole pour tout le reste du système. »

Diapo 8 : (Couche 2 - Avec l'exemple du pare-feu et de l'annuaire !)

« Ensuite, on descend d'un étage pour arriver au cœur de notre contribution : la couche numéro 2, la Traduction. C'est ici qu'on règle le vrai blocage. Un pare-feu ne parle qu'en "flux de données", alors qu'un annuaire d'entreprise attribue des "rôles". L'idée de cette couche, c'est d'agir comme un traducteur puissant. Elle analyse ces règles techniques pour aboutir à un format unifié. Grâce à ça, le système comprend enfin que le "Médecin" et le "Praticien" ont le même rôle. Les ambiguïtés disparaissent. »

Diapo 9 : (Couche 3)

« Pour terminer, la troisième couche : le Moteur d'inférence, qui agit un peu comme un juge. Maintenant qu'il a des règles bien traduites, il peut répondre à la question : "Est-ce que j'autorise cette personne à accéder au dossier ? ». Son vrai travail, c'est surtout de gérer les désaccords. S'il y a un conflit, bloquer systématiquement l'accès rendrait le système trop rigide. Une perspective serait plutôt de calculer un score de confiance pour prendre la bonne décision. »

Diapo 10 : (Conclusion punchy)

« Pour conclure, faire cohabiter ces politiques reste un grand défi qu'il faudra tester en conditions réelles. Mais au-delà de la technique, le défi est avant tout humain. La cybersécurité doit devenir un vrai sujet de stratégie globale pour l'entreprise, pas juste l'affaire des techniciens dans leur coin. En remettant du sens humain au-dessus de la technique, on configure mieux nos systèmes et on évite les failles. Merci à tous pour votre écoute ! »

10.4 Diapositives vidéo

Un Framework Sémantique Pour La Cohabitation De Politiques De Sécurité Hétérogènes

CHINOUN Riadh, DAHIR ALHUSSIN Mahmoud, MEZIANE Miloud, YAHIOUNE Smaïl

Contenu

1. Introduction
2. Solution
3. Conclusion

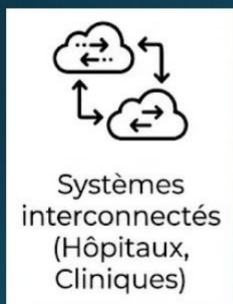
Introduction

- Contexte



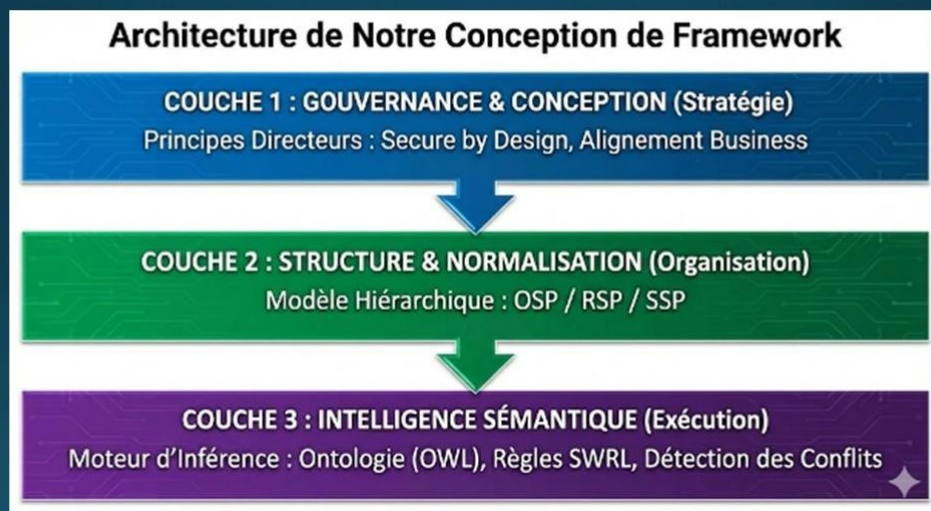
Introduction

- Problématique



Solution

Architecture en 3 couches



Couche 1



Couche 2



Couche 3



Conclusion